

保護 AI 應用程式的基礎架構

來源：<https://codelabs.developers.google.com/codelabs/production-ready-ai-with-gc/4-securing-ai-applications/securing-infrastructure-for-ai-applications?hl=zh-tw>

步驟數：8

「導入網路隔離、強化運算執行個體和受保護的儲存空間，確保 AI 開發環境安全無虞。」

目錄

1. [1. 簡介](#)
2. [2. 專案設定](#)
3. [3. 啟用 API](#)
4. [4. 設定安全的網路基礎](#)
5. [5. 部署安全的 Vertex AI Workbench 執行個體](#)
6. [6. 部署安全的 Cloud Storage bucket](#)
7. [7. 從實驗室到現實世界](#)
8. [8. 恭喜！](#)

1. 簡介

總覽

在本實驗室中，您將減輕 AI 開發環境基礎架構的常見威脅。您會導入安全控管機制，保護這個環境的核心元件。

背景資訊

您是開發團隊的資安代表，目標是建構一個環境，在盡量減少使用阻礙的同時，防範常見威脅。

下表列出您最想減輕的威脅。本實驗室中的特定工作會處理每項威脅：

威脅	緩解措施	已完成工作
透過遭濫用的開放通訊埠，未經授權進入網路。	建立私人虛擬私有雲，並限制 Vertex AI 存取權，只允許透過 Google Cloud 代理的單一使用者存取，而非透過公開 IP 位址。	設定安全網路基礎架構
使用過度授權的憑證，從遭入侵的運算執行個體提權。	為 Vertex AI 執行個體建立並指派最低權限服務帳戶。	部署安全的 Vertex AI Workbench 執行個體
運算資源的執行個體遭到入侵，導致系統遭竄改。	停用根存取權並啟用安全啟動功能，強化執行個體。	部署安全的 Vertex AI Workbench 執行個體
儲存空間設定錯誤，導致訓練資料和模型意外公開。	強制禁止公開存取 bucket，並使用統一 bucket 層級存取控管機制。	部署安全的 Cloud Storage bucket
資料集和模型構件遭到惡意或意外刪除或竄改。	啟用物件版本管理功能以利復原，並啟用資料存取記錄，確保所有活動都有不可變更的稽核追蹤記錄。	部署安全的 Cloud Storage bucket

快速參考

在本實驗室中，您將使用下列具名資源：

元件	名稱
虛擬私有雲名稱	<code>genai-secure-vpc</code>
子網路名稱	<code>genai-subnet-us-central1</code>
Cloud Router	<code>genai-router-us-central1</code>
Cloud NAT	<code>genai-nat-us-central1</code>

服務帳戶	<code>vertex-workbench-sa</code>
Vertex AI 執行個體	<code>secure-genai-instance</code>
儲存空間 Bucket	<code>secure-genai-artifacts-[PROJECT_ID]</code>

課程內容

本實驗室的內容包括：

- 佈建具備私人網路的虛擬私有雲，防範未經授權的流量。
 - 強化 Vertex AI Workbench 執行個體，防範開機套件和提權。
 - 保護 Cloud Storage bucket，避免未受監控的資料移轉和意外公開揭露。
-

步驟 2 · 約 0 分鐘

2. 專案設定

info

從做中學 免付費

立即取得 Google Cloud 抵免額，並完成這個實驗室。無須提供信用卡或付款方式。

啟用

Google 帳戶

如果沒有個人 Google 帳戶，請[建立 Google 帳戶](#)。

請使用個人帳戶，而非公司或學校帳戶。

公司和學校帳戶可能設有限制，導致您無法啟用本實驗室所需的 API。

登入 Google Cloud 控制台

使用個人 Google 帳戶登入 [Google Cloud 控制台](#)。

啟用計費功能

兌換 Google Cloud 抵免額 (選用)

如要參加這個研討會，您需要有具備抵免額的帳單帳戶。請使用本程式碼研究室頂端橫幅中的抵免額開始操作。如果已連結帳單帳戶，可以略過這個步驟。

設定個人帳單帳戶

如果使用 Google Cloud 抵免額設定計費，可以略過這個步驟。

如要設定個人帳單帳戶，請[前往這裡在 Cloud 控制台中啟用帳單](#)。

注意事項：

- 完成本實驗室的 Cloud 資源費用應不到 \$1 美元。
- 您可以按照本實驗室結尾的步驟刪除資源，以免產生後續費用。
- 新使用者可獲得價值 [\\$300 美元的免費試用期](#)。

建立專案 (選用)

如果沒有要用於本實驗室的現有專案，請[在這裡建立新專案](#)。

步驟 3 · 約 0 分鐘

3. 啟用 API

設定 Cloud Shell

專案建立完成後，請按照下列步驟設定 **Cloud Shell**。

啟動 Cloud Shell

前往 shell.cloud.google.com，如果看到要求授權的彈出式視窗，請點選「Authorize」(授權)。

設定專案 ID

在 Cloud Shell 終端機中執行下列指令，設定正確的**專案 ID**。將 `<your-project-id>` 替換為您在上述專案建立步驟中複製的實際專案 ID。

```
gcloud config set project <your-project-id>
```

現在，您應該會在 Cloud Shell 終端機中看到已選取正確的專案。

啟用 Vertex AI Workbench 和 Cloud Storage

如要在本實驗室中使用服務，您需要在 Google Cloud 雲端專案中啟用 Compute Engine、Vertex AI Workbench、IAM 和 Cloud Storage 的 API。

1. 在終端機中啟用 API：

```
gcloud services enable compute.googleapis.com notebooks.googleapis.com  
aiplatform.googleapis.com iam.googleapis.com storage.googleapis.com
```

或者，您也可以前往控制台中的個別頁面，然後點選「啟用」，啟用這些 API。

4. 設定安全的網路基礎

在這項工作中，您將為所有服務建立獨立的網路環境。使用[私有網路](#)並控管資料流，即可建構多層防禦機制，與可公開存取的資源相比，大幅減少基礎架構的攻擊面。這個安全網路基礎對於保護 AI 應用程式免遭未經授權存取至關重要。

建立虛擬私有雲和子網路

在這個步驟中，您會設定[虛擬私有雲 \(VPC\)](#) 和子網路。這會建立獨立的網路環境，成為防範未經授權網路連入的第一道防線。

1. 在 Google Cloud 控制台中，依序前往「VPC Network」(虛擬私有雲網路) > 「VPC networks」(虛擬私有雲網路)。使用 Google Cloud 控制台頂端的搜尋列搜尋「VPC 網路」，然後選取該項目。
2. 按一下「建立虛擬私有雲網路」。
3. 在「Name」(名稱) 中輸入 `genai-secure-vpc`。
4. 在「子網路建立模式」部分，選取「自訂」。
5. 在「New subnet」(新的子網路) 下方，指定下列屬性來建立子網路：

屬性	值 (輸入或選取)
名稱	<code>genai-subnet-us-central1</code>
區域	<code>us-central1</code>
IP 位址範圍	<code>10.0.1.0/24</code>
私人 Google 存取權	開啟

安全原因：Private Google Access 可讓沒有外部 IP 位址的資源透過 Google 私人網路存取 Google API (例如 Cloud Storage)，避免使用公開網際網路。

6. 點選「建立」。

建立 Cloud NAT 閘道

[Cloud NAT 閘道](#)可讓私人執行個體啟動傳出連線 (例如用於軟體更新)，不必擁有公用 IP 位址，也就是說，公用網際網路無法連線至這些執行個體。

1. 首先，請建立 Cloud Router。在 Google Cloud 控制台頂端的搜尋列中，搜尋並選取「Cloud Router」。
2. 按一下「建立路由器」。
3. 設定 Cloud Router，並提供下列資訊：

屬性	值 (輸入或選取)
----	-----------

名稱	genai-router-us-central1
網路	genai-secure-vpc (您剛建立的虛擬私有雲網路)
區域	us-central1

- 點選「建立」。
- 接著，依序前往「Network Services」>「Cloud NAT」。在 Google Cloud 控制台頂端的搜尋列中搜尋「Cloud NAT」，然後選取該項目。
- 按一下 [開始使用]。
- 使用下列項目設定 Cloud NAT 閘道：

屬性	值 (輸入或選取)
閘道名稱	genai-nat-us-central1
虛擬私有雲網路	genai-secure-vpc (您建立的虛擬私有雲網路)
區域	us-central1
Cloud Router	genai-router-us-central1 (你剛設定的路由器)

- 點選「建立」。
-

5. 部署安全的 Vertex AI Workbench 執行個體

您已建立安全的網路基礎，現在要在安全的虛擬私有雲中部署強化的 [Vertex AI Workbench 執行個體](#)。這個 Workbench 執行個體是您的開發環境，可為 AI 開發工作提供安全隔離的空間。先前的網路設定可確保這個執行個體不會直接暴露在公開網際網路上，進一步強化多層防禦機制。

建立最低權限的服務帳戶

建立具備最少必要權限的專屬[服務帳戶](#)，有助於支援[最小權限原則](#)。如果執行個體遭到入侵，這項做法可確保執行個體只能存取其功能明確需要的資源和執行動作，藉此限制「影響範圍」。

1. 前往 Google Cloud 控制台，依序點選「IAM 與管理」>「服務帳戶」。使用 Google Cloud 控制台頂端的搜尋列搜尋「服務帳戶」，然後選取該項目。
2. 按一下「建立服務帳戶」。
3. 在「Service account name」(服務帳戶名稱) 中輸入 `vertex-workbench-sa`。
4. 按一下 [建立並繼續]。
5. 授予下列角色：
 - `Vertex AI User`
 - `Storage Object Creator`
6. 按一下 [完成]。

建立工作台執行個體

在本步驟中，您將部署 Vertex AI Workbench 執行個體。這個執行個體已設定為在您先前建立的私有虛擬私有雲中執行，進一步與公用網際網路隔離。您也可以直接對執行個體套用額外的安全強化措施。

1. 前往 Google Cloud 控制台，依序點選導覽選單 (漢堡選單) > 「Vertex AI」> 「Workbench」。使用 Google Cloud 控制台頂端的搜尋列搜尋「Workbench」，然後選取副標題為「Vertex AI」的結果。
2. 按一下「建立新項目」，然後設定：

屬性	值 (輸入或選取)
名稱	<code>secure-genai-instance</code>
區域	<code>us-central1</code>

3. 點選「進階選項」。
4. 點按「機型」，然後勾選下列核取方塊：
 - 安全啟動
 - 虛擬信任平台模組 (vTPM)
 - 完整性監控。
5. 按一下「網路」，然後設定下列項目：

屬性	值 (輸入或選取)
網路	<code>genai-secure-vpc</code>
子網路	<code>genai-subnet-us-central1</code> (10.0.1.0/24)
指派外部 IP 位址	取消選取，因為您只會透過 Google Cloud 中的 Proxy 存取這個執行個體。

6. 按一下「IAM and security」(IAM 與安全性)，然後設定下列項目：

屬性	值 (輸入或選取)
使用者電子郵件地址	單一使用者，然後選取目前用來登入 Google Cloud 的電子郵件地址。
使用預設 Compute Engine 服務帳戶	取消選取核取方塊。
服務帳戶電子郵件地址	輸入為最低權限服務帳戶建立的電子郵件地址 (將 <code>[PROJECT_ID]</code> 替換為實際 ID)： <code>vertex-workbench-sa@[PROJECT_ID].iam.gserviceaccount.com</code>
執行個體的根目錄存取權	取消選取核取方塊。

7. 按一下「建立」。

注意：這個步驟需要幾分鐘才能完成，因為系統會佈建基礎運算資源。請等待執行個體完全佈建完成，再繼續操作。

存取 Vertex AI 執行個體

Vertex AI Workbench 執行個體現在處於臨時狀態，您可以安全地存取該執行個體。您透過 Google Cloud 的 Proxy 連線至執行個體，確保執行個體維持私密狀態，不會暴露在公開網際網路上，因此可降低未經要求且可能惡意流量的風險。

1. 前往「Vertex AI」>「Workbench」。如果執行個體剛完成佈建，您可能已在這個頁面。如果沒有，請使用 Google Cloud 控制台導覽選單 (漢堡選單) 或搜尋列前往。
2. 在清單中找出名為 `secure-genai-instance` 的執行個體。
3. 按一下執行個體右側的「Open JupyterLab」連結。

瀏覽器會開啟新分頁，讓您存取執行個體。您可以透過 Google Cloud 存取執行個體，但執行個體不會公開在網際網路上，因此可降低未經要求和潛在惡意流量的風險。

6. 部署安全的 Cloud Storage bucket

現在，請為資料集建立[安全的 Cloud Storage bucket](#)。AI 訓練資料、模型和構件會儲存在這裡。對這個 bucket 套用嚴格的安全設定，可防止機密資料意外公開，並防範惡意或意外刪除及竄改。確保珍貴的 AI 資產完整無缺且機密。

建立及設定 bucket

在這個步驟中，您將建立 Cloud Storage bucket 並套用初始安全性設定。這些設定會強制禁止公開存取，並啟用統一 bucket 層級存取控管機制，這對於控管資料存取權至關重要。

1. 在 Google Cloud 控制台中，依序前往「Cloud Storage」>「Bucket」。使用 Google Cloud 控制台頂端的搜尋列搜尋「Buckets」，然後選取該項目。
2. 點選「建立」。
3. 在「開始使用」中，將「名稱」設為完全隨機且不重複的名稱。
4. 繼續「選擇資料的儲存位置」，並設定下列項目：

屬性	值 (輸入或選取)
位置類型	區域
區域	us-central1

5. 繼續「選擇資料儲存方式」，並保留預設設定。
6. 繼續「選取如何控制物件的存取權」，並保留預設設定：

屬性	值 (輸入或選取)	原因
禁止公開存取	請選取「強制禁止公開存取」。	公開存取權預防措施 會覆寫 IAM 的任何變更，避免物件在無意間暴露於網際網路。
存取權控管	保持選取「統一」。	雖然 ACL 似乎是精細控管 (即最小權限) 的較佳選擇，但與其他 IAM 功能搭配使用時，會造成複雜性和不可預測性。請考量 統一值區層級存取權 的優缺點，以防資料暴露。

7. 繼續「選擇保護物件資料的方式」，並保留預設設定：

屬性	值 (輸入或選取)	原因
虛刪除政策 (用於資料復原)	請保持選取「虛刪除政策 (用於資料復原)」。	如果儲存空間中的內容遭到意外或惡意刪除，您可以使用 虛刪除 功能在保留期限內還原內容。
物件版本管理 (用於版本管控)	選取「物件版本管理 (用於版本管控)」。	物件版本管理功能可讓您從意外或惡意覆寫作業中復原，例如攻擊者將良性檔案替換為含有漏洞攻擊程式碼的檔案。

每個物件的版本數量上限	3	雖然這是任意值，且可能會增加費用，但必須大於 1，才能復原為先前版本。如果攻擊者可能會嘗試多次覆寫，您可能需要更完善的版本控管備份策略。
非現行版本的有效期限	7	建議保留舊版 7 天，但如果需要長期儲存，可以保留更久。

注意：資料保護和資料加密的其他選項 (例如保留和自訂金鑰管理) 可能適用於以法規遵循為基礎的使用情境，因此請進一步瞭解各項選項，判斷何時應考慮使用。單就安全性而言，目前的設定已足夠。

- 點選「建立」。
- 如果出現「系統會禁止公開存取」的彈出式視窗，請保留預設勾選的方塊 (「強制禁止公開存取這個 bucket」)，然後點選「確認」。

啟用資料保護和記錄功能

為確保資料不可變更且可供稽核，請為值區啟用物件版本控管，並設定[資料存取記錄](#)。物件版本管理功能可讓您從意外刪除或覆寫的物件中復原，而資料存取記錄則提供值區中所有活動的完整稽核追蹤記錄，有助於安全監控和法規遵循。

- 前往 Google Cloud 控制台，依序點選「IAM 與管理」>「稽核記錄」。在 Google Cloud 控制台頂端的搜尋列中，搜尋並選取「稽核記錄」。
- 使用篩選器搜尋並選取「Google Cloud Storage」。
- 在隨即顯示的面板中，勾選「資料讀取」和「資料寫入」的方塊。
- 按一下 [儲存]。

7. 從實驗室到現實世界

您剛才在臨時實驗室環境中完成一系列步驟，但您套用的原則和設定，是確保 Google Cloud 上實際 AI 專案安全的藍圖。以下說明如何將所學知識應用於工作，從簡單的實驗室轉移到可供正式環境使用的設定。

您剛建構的資源 (私人 VPC、強化型 Workbench 執行個體和安全儲存空間) 可做為任何新 AI 專案的安全入門範本。您的目標是讓自己和團隊預設採用這個安全基礎，並輕鬆達成目標。

安全網路：您的私人工作區

如何在設定中使用這項功能

每次啟動新的 AI 專案 (例如「customer-churn-prediction」、「image-classification-model」) 時，您都會複製這個網路設定。您可以建立專屬虛擬私有雲 (`churn-pred-vpc`)，或使用預先核准的共用網路。這會成為專案的獨立「沙箱」。您設定的 Vertex AI Workbench 等開發環境，就位於這個受保護的空間內。您會透過安全 Proxy (「Open JupyterLab」) 連線至該執行個體，絕不會將其暴露於公開網際網路。

連線至正式環境

在正式環境中，您會進一步考慮下列事項：

- **基礎架構即程式碼 (IaC)**：您可以使用 [Terraform](#) 或 [Cloud Deployment Manager](#) 等工具定義這個網路，而不使用 Cloud 控制台。您可以在幾分鐘內為新專案部署安全網路基礎，確保流程可重複執行及稽核。
- **Shared VPC**：在大型機構中，中央網路團隊通常會管理 Shared VPC。開發人員可獲得授權，在集中管理的安全網路中，將執行個體和服務啟動至特定子網路。原理相同，您仍是在私人空間中作業，但這個空間屬於較大的共用基礎架構。
- **VPC Service Controls**：為確保最高安全性，您會將整個環境包裝在 VPC Service Controls 範圍內。這項強大功能可確保只有私人網路範圍「內」的授權資源，才能存取 Cloud Storage 等服務，防止資料外洩。

強化運算：安全開發與訓練中心

如何在設定中使用這項功能

`secure-genai-instance` 是您日常使用的 AI 開發機器。您可以使用 JupyterLab 介面執行下列操作：

- 在筆記本中編寫及測試模型程式碼。
- 安裝 Python 程式庫 (`pip install ...`)。
- 請使用小型到中型資料集進行實驗。您設定的安全性 (沒有公開 IP、最低權限服務帳戶、沒有根存取權、安全啟動) 會在背景中透明地執行。您可以專注於 AI 工作，因為執行個體已強化，可抵禦常見攻擊。

連線至正式環境

您通常不會在實際工作環境的單一 Workbench 執行個體上執行大規模訓練。不過，您可以透過下列方式將工作投入生產：

- **從筆記本到管道**：您會從筆記本取得程式碼，並將其正式化為指令碼。然後，這個指令碼會以 [Vertex AI 自訂訓練工作](#) 的形式執行，或是做為 [Vertex AI Pipeline](#) 中的步驟執行。
- **容器化**：將訓練程式碼及其依附元件封裝至 [Docker 容器](#)，並儲存在 [Artifact Registry](#) 中。確保程式碼每次都能在一致且可預測的環境中執行。
- **服務帳戶是關鍵**：您建立的 `vertex-workbench-sa` 服務帳戶至關重要。在正式環境中，自動執行的 Vertex AI 訓練工作會使用這個 (或類似的) 最小權限服務帳戶，確保自動工作只具備絕對必要的權限。

安全儲存空間：您的中央構件存放區

如何在設定中使用這項功能

`secure-genai-artifacts` bucket 是專案資料的單一可靠資料來源。這項功能不只適用於初始資料集，您會使用這項功能儲存：

- 原始和預先處理的訓練資料。
- 長時間訓練期間的模型檢查點。
- 最終訓練完成的模型構件 (`.pkl`、`.pb` 或 `.h5` 檔案)。
- 評估結果和記錄。您套用的安全性設定 (避免公開存取權、統一值區層級存取權、版本管理和稽核記錄) 表示您可以放心地將這個值區做為中央儲存庫，避免資料外洩和意外刪除。

連線至正式環境

如要在正式環境中管理及控管原則，您也應考慮：

- **生命週期政策**：為管理成本，您可以設定生命週期政策，自動將舊版模型或資料集移至費用較低的儲存空間類別 (例如 Nearline 或 Coldline)，或在特定時間後刪除。
- **跨專案權限**：在正式版管道中，資料工程團隊可能會從其他 Google Cloud 雲端專案填入這個 bucket。您啟用的統一 bucket 層級存取權可簡化這些跨專案 IAM 權限的管理作業，並確保安全無虞，不必使用複雜 (因此容易設定錯誤) 的 ACL。

縱觀全局：將安全性設為預設

採用這個模型後，安全防護機制不再是事後考量，而是基礎。您不再只是開發人員，而是團隊的資安先鋒。新團隊成員加入時，您不會提供不安全的公開機器。您可讓他們存取預先設定的安全環境，以最簡單的方式安全地工作。這種做法可避免常見的資料外洩和系統遭入侵原因，直接降低業務風險，讓團隊放心創新及建構強大的 AI 應用程式。

8. 恭喜！

恭喜！您已成功為 AI 開發環境建構並稽核多層式安全基礎架構。您已建立安全網路 perimeter，並採用「預設拒絕」防火牆防護機制、部署強化的運算執行個體、保護資料 bucket，以及使用記錄檔確認控管機制是否正常運作。

重點回顧

在本實驗室中，您完成了下列工作：

- 佈建具備私人網路的安全虛擬私有雲，以防範未經授權的流量。
 - 部署防範開機套件和提權的強化型 Vertex AI Workbench 執行個體。
 - 保護 Cloud Storage bucket，避免未受監控的資料移轉和意外公開。
 - 實作最低權限服務帳戶，限制潛在的「影響範圍」。
 - 啟用物件版本控管和資料存取記錄，確保資料受到保護，並提供不可變更的稽核追蹤記錄。
-